SECAUDIT 046 — Full multi-dimension audit @ 0.7.525 (525D)

Date: 2026-08-14

Target: SnapSmack core at tag `v0.7.525D` (SNAPSMACK_VERSION `Alpha 0.7.525`), the live **dev** track.

Method: 9 parallel single-dimension reviewers (auth, authz, SQLi, path/LFI, upload/RCE, federation/SSRF, CSRF, secrets/updater, XSS), each reading real code and confirming reachability.

> *Note on prior audit: the previous pass was run against a stale checkout on the **stable** track (0.7.124, May). This audit was reset onto `v0.7.525D` first. Findings below are confirmed present in 525D.*

Severity roll-up

#	Sev	Title	File(s)
1	CRITICAL	Editor → admin self-promotion	smack-edit-user.php
2	CRITICAL	Editor can create/delete admins	smack-users.php
3	CRITICAL	Recovery-kit import = arbitrary file write → RCE	core/recovery-engine.php, smack-disaster.php
4	CRITICAL	Federation actor spoofing / takeover (keyId not origin-bound)	core/smackverse.php sv_verify_signature
5	HIGH	Admin surface is role-blind (root of #1/#2)	core/auth-smack.php
6	HIGH	Hub (Smack Central) login has no brute-force lockout	smack-central/sc-login.php
7	HIGH	download_salt never generated → public hardcoded default	download.php, core/ftp-engine.php, core/secret-store.php, +consumers
8	HIGH	CSRF via GET: account/content/community/federation deletion & moderation	smack-users.php, smack-community-users.php, smack-comments.php, smack-fediverse.php, smack-media/pages/albums/cats/blogroll/manage/post-long
9	HIGH	Media-library upload accepts any extension → webshell	smack-media.php
10	HIGH	Federation Update/Delete of comments not bound to author	core/smackverse.php
11	HIGH	Stored XSS via javascript: URI on public Photo Challenge board/HoF	photochallenge-board.php, photochallenge-hof.php, core/photochallenge.php
12	MED	CSRF via GET: backup restore/breach-clear, FTP push	smack-back.php, smack-ftp.php
13	MED	Skin active_skin path traversal (stored, CSRF-reachable)	smack-skin.php
14	MED	Stored XSS via javascript: URI in admin fediverse panel	smack-fediverse.php
15	LOW	Password-reset tokens stored in plaintext	core/auth-recovery.php, core/community-auth.php
16	LOW	sso.php session cookie missing Secure behind TLS proxy	sso.php

#	Sev	Title	File(s)
17	LOW	Username enumeration via login timing	snap-in.php
18	LOW	Updater signature fail-open if pubkey self-heal cannot write	core/updater.php
19	LOW	Open redirect via ?ap=remote-follow	core/smackverse.php
20	LOW	RSS peer fetch has no SSRF guard / TLS off	cron-rss-fetch.php
21	LOW	Logout via GET (logout CSRF)	core/auth-smack.php
22	LOW	Reflected canonical/og:url unescaped	core/meta.php

Clean dimensions

- **SQL injection:** none — codebase is consistently PDO-parameterized.
- **Federation DB exfiltration** (prior flag): absent in 525D.
- **Updater package signing:** sound (Ed25519 over checksum, pinned pubkey, staged verify-before-extract). Only the narrow fail-open in #18.
- **Randomness / password hashing / hardcoded creds:** clean (random_bytes, password_hash, no secrets in source).
- **Normal image upload / skin install:** well-defended (finfo MIME, GD re-encode, zip-slip + Ed25519). Skin-UPLOAD path confirmed removed.

Remediation status (fixed in 0.7.526)

#	Sev	Status	Fix
1	CRITICAL	FIXED	`smack_require_admin()` + central admin-only page gate in auth-smack.php; explicit gate on smack-edit-user.php
2	CRITICAL	FIXED	Same central gate + explicit gate on smack-users.php
3	CRITICAL	FIXED	recovery-engine.php blocks traversal/absolute/executable/dotfile restore targets + realpath confinement; smack-disaster.php requires CSRF token for browser imports
4	CRITICAL	FIXED	sv_verify_signature() binds keyId origin to actor id origin + publicKey.id == keyId
5	HIGH	FIXED	Central admin-only gate (root cause of 1/2)
6	HIGH	FIXED	sc-login.php: self-contained 5/15-min lockout on hub DB + dummy verify
7	HIGH	FIXED	snap_ensure_download_salt() self-heal (+FTP re-encrypt) in secret-store.php; install.php seeds random salt; all consumers rewired; smack-ftp.php migrated
8	HIGH	FIXED	csrf_verify()/csrf_url() + token threaded through all GET mutation handlers/links (users, community-users, comments, fediverse, media, pages, albums, cats, blogroll, manage, post-long, back, ftp)

#	Sev	Status	Fix
9	HIGH	FIXED	smack-media.php: finfo MIME whitelist (jpg/png/webp/gif) + media_assets/.htaccess PHP-deny + CSRF on GET delete
10	HIGH	FIXED	smackverse.php Update/Delete of snap_comments now bound to `ap_actor_url`
11	HIGH	FIXED	http(s) scheme guard at ingest (sv_ingest_timeline) + at all render sinks
12	MED	FIXED	csrf_verify() + token on smack-back.php restore/restore_all and smack-ftp.php actions
13	MED	FIXED	smack-skin.php rejects non-installed skins; uses sanitized slug for paths + the active_skin setting
14	MED	FIXED	Neutralised by #4 (a `javascript:` actor id can't pass verification) + render-sink scheme guard
15	LOW	FIXED	auth-recovery.php stores/looks up reset tokens as sha256
16	LOW	FIXED	sso.php cookie Secure honours X-Forwarded-Proto
17	LOW	FIXED	snap-in.php dummy password_verify on unknown username
18	LOW	DEFERRED	Updater is sound in practice (fail-open needs read-only core/ + placeholder state). Not touched — the updater is the only fix-delivery path; a mistake there bricks updates. Documented, revisit deliberately.
19	LOW	FIXED	sv_remote_follow_url() restricts redirect to https on the same instance host
20	LOW	FIXED	cron-rss-fetch.php: rss_url_is_safe() refuses feed URLs resolving to private/reserved IPs, caps redirects, and turns TLS verification on
21	LOW	FIXED	Sec-Fetch-Site guard on `?logout=1` (auth-smack.php) and logout.php drops forged cross-site background logout requests without touching any logout link
22	LOW	FIXED	core/meta.php escapes canonical/og:url

All 4 CRITICAL, all 7 HIGH, all 3 MED, and 8 of 9 LOW fixed. Only #18 (updater fail-open) remains deferred — parked as a tracked follow-up because the updater is the sole fix-delivery path and a wrong assumption there could lock the fleet out of all updates. Every code fix is tagged `SECAUDIT 046` inline; all changed files pass `php -l` and retain their EOF markers. Shipped in 0.7.526.

Post-remediation verification (adversarial re-audit)

Two adversarial verifiers re-checked the fixes against the patched tree. Authz + CSRF were confirmed solid (denylist complete, all `user_role` write paths gated, every GET-mutation handler carries `csrf_verify()` with tokens threaded

through every trigger link). The federation/salt/upload verifier found **3 residual gaps, all now fixed**:

- **V1 (MED)** — the federated-comment **Create** upsert (`ON DUPLICATE KEY UPDATE`) collided on `ap_object_id` alone, so a signed remote actor could still overwrite another actor's comment (the Update/Delete binds were correct, the Create sibling was missed). Fixed: `comment_text = IF(ap_actor_url = VALUES(ap_actor_url), VALUES(comment_text), comment_text)` on both Create inserts (core/smackverse.php).
- **V2 (MED)** — the recovery-kit target guard checked only the final extension, so `shell.php.jpg` bypassed it (executes under Apache `AddHandler`). Fixed: reject if ANY dot-separated token is a blocked extension (core/recovery-engine.php).
- **V3 (LOW)** — `smack-post-solo.php` still trusted the client filename extension on upload. Fixed: extension derived from finfo MIME, raster images only.
- **V4 (LOW, race)** — first-boot salt heal could mint two salts under concurrency and orphan the FTP password. Fixed: advisory `GET_LOCK` + re-read under the lock (core/secret-store.php).

Re-verified: all four re-fixes pass `php -l`, EOF markers intact.